

Product Hunt launch copy — firm-bot v0.1

Mine-FNL

Product Hunt launch copy — firm-bot v0.1

Copy-paste ready. Verify the tagline and short description lengths before submitting; Product Hunt is strict about both.

Tagline (max 60 chars)

Local-first RAG for legal & audit, citations enforced

(54 chars)

The existing launch tag is "Local-first RAG chatbot builder for legal & audit" (52 chars). This variant keeps the local-first positioning and adds the citation-enforcement claim, which is the core engineering commitment. Drop either; both work.

Short description (max 260 chars)

Cloud RAG is fine for most teams. For law firms and audit shops on privileged material, the vendor sits on your chain of cust

(242 chars including the single line break between paragraphs; Product Hunt renders as two short paragraphs)

Long description

The problem

Cloud RAG products — Harvey, Spellbook, Glean, ChatGPT Enterprise, Microsoft 365 Copilot — have changed how professional services teams read their own documents. They have not changed *who* reads them. Every cloud vendor adds at least one, usually several, subprocess or to the chain of custody for the work product that defines a professional services firm: contracts, transaction documents, engagement letters, audit working papers, opinion letters, board materials.

For most of the profession this is a non-issue. For a non-trivial subset — any firm handling matters that touch attorney-client privilege, GDPR-regulated personal data, HIPAA-protected health information, government classified material, export-controlled technical data, or matters under a protective order — the vendor's presence on the chain of custody is disqualifying. SOC 2 Type II reports and DPAs are necessary evidence in a vendor risk assessment. They are not the assessment. For high-risk systems — those processing the firm's most sensitive work product — many firms conclude that no vendor's controls can match their own.

What firm-bot does

firm-bot is a local-first RAG chatbot builder for professional services firms that cannot use cloud RAG for these reasons. Drop PDFs, EMLs, and DOCX files into a per-firm folder; firm-bot builds a chat endpoint that answers questions with citations on every claim. Nothing leaves the box — no cloud calls, no telemetry, no vendor.

The architecture is a six-stage pipeline. **Ingest** parses PDFs (with Tesseract OCR fallback for image-only PDFs), EMLs (via Python `email` with RFC 2047 decoding), and DOCX (via `python-docx` with header detection). **Chunk** runs the structure-aware regex cascade (Article §, Section, Title Case, WHEREAS preambles, numbered clauses). **Embed** runs `sentence-transformers` or `fastembed` locally on CPU / CUDA / Apple Silicon Metal. **Retrieve** does hybrid BM25 + dense search fused via Reciprocal Rank Fusion (RRF, k=60). **Answer** generates with a citation-required system prompt and streams via Server-Sent Events. **Guard** runs a second LLM that audits citation coverage and flags ungrounded claims.

Every stage is replaceable, individually testable, and individually observable. Prometheus `/metrics`, structured JSON logs with PII redaction, and per-request UUIDv7 are opt-in via `pip install firm-bot[observability]`. The deployment runs as a service you'd be willing to operate in production — because it is one.

What's different

- **Structure-aware chunker.** Recognises Article §, Section, Title Case headings, WHEREAS preambles, numbered clauses (1., (a)). Closes a 0.70→0.95 precision@k gap vs. naive sliding-window chunking on contracts that don't prefix sections with "Section".
- **Citation-required prompt + LLM-as-judge guard.** Every claim must carry a `[file:page]` marker; the guard flags ungrounded claims. 100% citation coverage in our e2e test on the CUAD subset.
- **Hybrid retrieval.** BM25 + dense via Reciprocal Rank Fusion (k=60). Cross-encoder reranker (`cross-encoder/ms-marco-MiniLM-L-6-v2`) is opt-in; our benchmark showed no lift on the CUAD fixture, so default is no rerank.

- **RAGAS-style quality metrics.** Faithfulness 0.91, answer relevancy 0.87, context precision 0.78, context recall 0.72 on the CUAD subset, computed natively in `eval/ragas.py` without the heavy `ragas` package.
- **Observability extras.** Prometheus `/metrics` (firmbot_* collectors), structured JSON logs with PII redaction (SSN/EIN/email/phone/credit-card with Luhn validation/IBAN/IPv4), request-id propagation via UUIDv7. Opt-in via `pip install firm-bot[observability]`.
- **STRIDE threat model in SECURITY.md.** Per-IP rate limit (10 RPS / 20 burst), body cap (413 before read), CORS allow-list (fail-closed), log redaction filter, per-firm filesystem isolation. Out-of-scope threats are listed explicitly so reviewers don't have to guess.
- **MIT-licensed open source.** 129 tests, 74.47% line coverage (CI-enforced floor), `ruff + mypy --strict` clean. Reproducible benchmarks via `eval/cuad.py` and `eval/load.py`.

Try it

```
git clone https://github.com/Mine-FNL/firm-bot
cd firm-bot
pip install -e ".[dev,observability]"
ollama pull qwen2.5-coder:7b
firm-bot serve
```

Open <http://localhost:8000>, drop a PDF into the per-firm folder, ask a question, see the citation.

Limitations

Honest about v0.1. Prompt injection via corpus content is not defended (open problem across the industry; mitigation is application-layer). The model ceiling is the deployed model — a 7B local model is a 7B local model, and cloud vendors using GPT-4-class models have a materially higher ceiling. Benchmark coverage is a 10-contract CUAD subset plus a 200-query concurrent load benchmark, not a general legal Q&A benchmark. No multi-user authentication in core (opt-in OAuth middleware skeleton ships; production deployments add a reverse proxy or wait for v0.2). The chunker is validated on legal texts only; mixed corpuses (emails, mixed correspondence) need a hybrid pass.

Repository: <https://github.com/Mine-FNL/firm-bot> **Documentation:** <https://mine-fnl.github.io/firm-bot> **Whitepaper:** [WHITEPAPER.md](#) in the repo, 928 lines, versioned with the software.

Maker's first-comment reply

Made this because I kept having the same conversation: a firm wanted to put their contracts in a vector store, but in-house c
v0.1, real numbers, real source. Happy to walk through the STRIDE threat model with anyone evaluating it.

Maker's launch-day comment

firm-bot is on Product Hunt today. Local-first RAG for legal & audit. Citations enforced. MIT. If you've wrestled with "vendc

Themes to hunt for in launch-day comments

These are the four conversations the launch team should be ready for. Skim the comment queue every 15-30 minutes on launch day; the first 6 hours shape the front page.

1. **Privilege / compliance questions.** Anyone asking about attorney-client privilege chain of custody, GDPR/HIPAA, SOC 2 vendor risk assessment, or protective orders. These are the core audience. Link to `SECURITY.md` and the threat model summary in `WHITEPAPER.md` §2. Offer to walk through the STRIDE table.
2. **Comparison with Harvey / Spellbook / Glean.** This will come up in the first hour. Be honest: cloud vendors have a higher model ceiling, broader feature set, polished UX. firm-bot is for the cases where local-first is required, not a wholesale replacement. Avoid the "vs" framing; the deployment pattern several pilots use is "cloud RAG for general productivity, firm-bot for the corpus that can't leave the building."
3. **Deployment on M-series Macs.** Solo practitioners and small firms run on Apple Silicon. Confirm Metal acceleration works for sentence-transformers; link to the single-machine deployment section of the whitepaper. If a comment surfaces a rough edge, capture it as an issue and reply publicly with the issue link.
4. **Prompt injection.** This will come up — it's the standard criticism of any RAG system in 2026. Be direct: firm-bot does not defend against prompt injection via corpus content. It's listed in `SECURITY.md` as explicitly out of scope, with the mitigation path (application-layer input classifiers, instruction-defence prompts, output filtering). Anyone suggesting a defensible mitigation approach is gold; engage substantively and link to the issue tracker.